

Google OAuth verification — submission copy + checklist

This is the exact copy + checklist for getting "Sign in to enisnjbxqaliydepacc.supabase.co" replaced with "Sign in to Taxottic" and clearing the unverified-app warning. Walk through it from top to bottom.

Time: ~30 minutes of dashboard clicking, then 1-4 weeks of Google review.

0. Pre-flight (5 min)

You'll need:

- ☐ Logo as a square PNG, **120×120 px or larger**, transparent or white background. Use `brand-icons/source/Icon.png` (white) on a green tile by exporting `brand-icons/web/public/icon-512.png` (gradient green tile, 512×512 — already in the repo).
 - ☐ Owner of the **taxottic.com** domain logged into Google Search Console at <https://search.google.com/search-console> — if you haven't, add the property and verify via DNS TXT.
 - ☐ A working email at the **taxottic.com** domain for support contact (e.g. `support@taxottic.com` or `hello@taxottic.com`). Google requires the support email match the verified domain.
-

1. Google Cloud project (5 min)

- <https://console.cloud.google.com/> → top-left dropdown → **New Project**.
 - Name: `Taxottic`. Organization: leave "No organization" if you don't have a Google Workspace; otherwise pick yours.
 - Open the new project.
-

2. OAuth consent screen (10 min)

APIs & Services → **OAuth consent screen** → **External** → **Create**.

Paste the following:

App information

- **App name:** Taxottic
- **User support email:** support@taxottic.com
- **App logo:** upload brand-icons/web/public/icon-512.png

App domain

- **Application home page:** https://taxottic.com
- **Application privacy policy link:** https://taxottic.com/legal/privacy
- **Application terms of service link:** https://taxottic.com/legal/terms

Authorized domains

- taxottic.com

Developer contact information

- support@taxottic.com

Click **Save and continue**.

Scopes

Click **Add or remove scopes** and select these three:

- openid
- .../auth/userinfo.email
- .../auth/userinfo.profile

Click **Update** → **Save and continue**.

Test users

While the app is unverified, add yourself + 1-2 trusted teammates as test users. Save and continue.

Summary

Review → **Back to dashboard**.

3. OAuth client (5 min)

APIs & Services → **Credentials** → **Create Credentials** → **OAuth client ID**.

- **Application type:** Web application
- **Name:** Taxottic web
- **Authorized JavaScript origins:**

- `https://taxottic.com`
- `https://hq.taxottic.com`
- **Authorized redirect URIs:**
 - `https://enisnjbxqaliydepacc.supabase.co/auth/v1/callback`

Click **Create**. Copy the **Client ID** and **Client secret** that pop up.

4. Plug into Supabase (2 min)

Supabase dashboard → project `taxottic` → **Authentication** → **Providers** → **Google** → **Enable**.

- **Client ID:** paste from step 3.
- **Client Secret:** paste from step 3.
- **Authorized Client IDs:** leave blank.
- Save.

Also under **Authentication** → **URL Configuration**:

- **Site URL:** `https://taxottic.com`
- **Redirect URLs** (additional allowed): add `https://hq.taxottic.com/**` and `https://taxottic.com/**`.

Save.

Sign in via Google from `https://taxottic.com/login`. The consent screen should now read **Sign in to Taxottic** with your logo. The "unverified app" warning will still appear because we haven't submitted yet — that comes next.

5. Submit for verification (5 min, then wait 1-4 weeks)

Back in **OAuth consent screen** → **Publish app** → **In production**.

You'll be asked to **submit for verification**. Paste the following where prompted:

Why does your app need each requested scope?

Taxottic is a tax forecasting and deduction-tracking service for freelancers, small businesses, and tax-prep firms. We use the basic OpenID Connect scopes (`openid` , `email` , `profile`) for the sole purpose of authenticating the user's Taxottic session and personalising their account display (name + avatar). We do not request any sensitive or restricted scopes. We do not access Gmail, Drive, Calendar, or any other Google API.

How will the data be used?

The user's Google email is used as their Taxottic account identifier. Their full name and profile photo are displayed in the Taxottic header so they can confirm they are signed into the right account. Data is never shared with third parties for advertising, never used to train any AI model, and is processed only as described in our Privacy Policy (<https://taxottic.com/legal/privacy>).

Limited Use confirmation

Taxottic's use and transfer of information received from Google APIs adhere to the Google API Services User Data Policy, including the Limited Use requirements.

Demo video (only if Google asks for one — usually not for basic scopes)

If asked, screen-record the following 30-second flow:

1. Open <https://taxottic.com> in an incognito window.
2. Click **Sign in** → **Continue with Google**.
3. Pick a Google account.
4. Land on the Taxottic dashboard.
5. Click avatar → **Sign out**.

Upload to a private YouTube link and share with Google.

6. Verify it took (1 min after Google approves)

Once Google emails approval:

- Open <https://taxottic.com/login> in incognito → **Continue with Google**.
- The consent screen should say **Sign in to Taxottic**, show your logo, and have **no unverified-app warning**.
- The list of scopes should be: "See your primary Google Account email address", "See your personal info, including any personal info you've made publicly available", "Associate you with your personal info on Google".

If the page still says `enisnjbxqaliydepacc.supabase.co`, the most common cause is that the Supabase provider config is still using the default Google client. Re-check step 4.

Microsoft equivalent (15 min)

The same shape, on <https://entra.microsoft.com>.

1. App registrations → New registration:

- Name: `Taxottic`
- Supported account types: **Accounts in any organizational directory and personal Microsoft accounts**
- Redirect URI: **Web** → `https://enisnjbbxqaliydepacc.supabase.co/auth/v1/callback`

2. Branding & properties:

- Logo: upload `brand-icons/web/public/icon-512.png`
- Home page URL: `https://taxottic.com`
- Terms of service: `https://taxottic.com/legal/terms`
- Privacy statement: `https://taxottic.com/legal/privacy`
- Publisher domain: `taxottic.com` (verify via DNS TXT or hosted file)

3. Certificates & secrets → New client secret: copy the secret value.

4. Supabase → Authentication → Providers → Azure → Enable:

- **Client ID:** from registration overview.
- **Client Secret:** from step 3.
- **Azure Tenant URL:** `https://login.microsoftonline.com/common/v2.0`
- Save.

Microsoft does not have an "unverified app" warning to clear unless you go after Microsoft Partner Network publisher verification. The sign-in screen will say "Sign in to Taxottic" as soon as the registration's display name is `Taxottic` (it is, from step 1).

What to expect

- Google verification turnaround: typically **1-4 weeks** for basic scopes. They may email back with clarification questions; reply promptly.
- Until verified, users see "Google hasn't verified this app" and a small "Continue (unsafe)" link. The flow still works for test users you've allow-listed.
- Microsoft is approved as soon as you click Save — no review queue for basic scopes.